

“Your Doctor is Spying on You”: An Analysis of Data Practices in Mobile Healthcare Applications

Luke Stevenson
Computer Science
University of Denver
Denver, Colorado, USA.
luke.stevenson@du.edu

Sanchari Das
Information Sciences and Technology
George Mason University
Fairfax, Virginia, USA.
sdas35@gmu.edu

Abstract—Mobile healthcare (*mHealth*) applications promise convenient, continuous patient–provider interaction but also introduce severe and often underexamined security and privacy risks. We present an end-to-end audit of 272 Android *mHealth* apps from Google Play, combining permission forensics, static vulnerability analysis, and user review mining. Our multi-tool assessment with MobSF, RiskInDroid, and OWASP Mobile Audit revealed systemic weaknesses: 26.1% request fine-grained location without disclosure, 18.3% initiate calls silently, and 73 send SMS without notice. Nearly half (49.3%) still use deprecated SHA-1 encryption, 42 transmit unencrypted data, and 6 remain vulnerable to *StrandHogg 2.0*. Analysis of 2.56M user reviews found 28.5% negative or neutral sentiment, with over 553,000 explicitly citing privacy intrusions, data misuse, or operational instability. These findings demonstrate the urgent need for enforceable permission transparency, automated pre-market security vetting, and systematic adoption of secure-by-design practices to protect Protected Health Information (PHI).

Index Terms—mHealth; user experience; privacy; security.

I. INTRODUCTION

Mobile healthcare (*mHealth*) applications are reshaping digital health by enabling continuous, remote patient–provider interaction across diagnostics, treatment, and monitoring workflows. They deliver capabilities ranging from real-time vital sign monitoring and medication adherence tracking to teleconsultations and insurance claims management [1], [2]. However, their deep integration with mobile devices and direct handling of Protected Health Information (PHI) greatly expands the attack surface for privacy breaches and malicious exploitation [3]–[8]. Breaches of PHI can cause severe and long-lasting harm, including large-scale identity theft, fraudulent insurance claims, targeted discrimination, and psychological distress [9]–[12]. Regulatory frameworks such as HIPAA [13] and GDPR [14] mandate strict controls over data collection, storage, transmission, and sharing. However, enforcement remains inconsistent, particularly for consumer-oriented *mHealth* applications that fall outside medical device classifications [15]–[20]. This regulatory blind spot enables insecure default configurations, deprecated cryptographic protocols, and opaque data-sharing practices to proliferate in app marketplaces with minimal oversight.

To examine these risks, we conducted a multi-faceted audit of 272 Android *mHealth* applications from Google Play.

Using *MobSF*, *RiskInDroid*, and *OWASP Mobile Audit*, we performed static vulnerability analysis, permission forensics, and cryptographic inspections. These technical assessments were paired with sentiment and thematic analysis of over 2.5M user reviews, enabling correlation between measurable security weaknesses and user-reported trust, privacy, and usability concerns. This study addresses three research questions: **RQ1:** What proportion of *mHealth* applications exhibit permission overreach, insecure cryptographic implementations, or exploitable vulnerabilities, and how are these weaknesses characterised in static analysis?

RQ2: To what extent do technical weaknesses such as insecure permission use, outdated cryptography, and misconfigured network security correlate with user-reported privacy, security, and usability issues in *mHealth* applications?

RQ3: What misconfiguration and permission misuse patterns can be extracted from this evidence, and how can they inform enforceable secure-by-design and regulatory practices?

Our evaluation uncovered a layered security and privacy deficit across the *mHealth* ecosystem. Manifest inspection revealed 2,252 instances of unnecessarily exported broadcast receivers and 1,232 cases of exported permissions without defined protection levels. Certificate analysis showed 22 applications configured to trust all TLS certificates and 2 with certificate pinning deliberately disabled. *RiskInDroid* detected frequent misuse of high-impact capabilities, including `WRITE_SETTINGS` in 130 applications and `MANAGE_ACCOUNTS` in 117, often without any declared need. *OWASP Mobile Audit* reported an average of 44 critical and more than 2,000 high-severity issues per app, with improper credential handling and insecure communication among the most common weaknesses. Review mining revealed that usable security failures, including broken authentication flows and inconsistent password policies between mobile and web clients, accounted for 553,495 reviews, representing 21.6% of all feedback and exceeding direct privacy-related complaints. These results show that *mHealth* risks are deeply embedded in both code-level design choices and operational execution.

- We conduct an end-to-end security evaluation of 272 Android *mHealth* applications, integrating static byte-code and manifest auditing, fine-grained permission usage forensics from API call tracing, and sentiment and

topic mining of 2.56M user reviews to build a multi-dimensional risk model.

- We identify technical weaknesses including insecure cryptographic primitives, reliance on deprecated APIs, misconfigured network security policies allowing plaintext traffic, and insecure X.509 certificate validation bypasses enabling man-in-the-middle attacks.
- We identify statistically significant correlations between technical weaknesses and user sentiment: apps exhibiting permission overreach ($r = 0.62, p < 0.001$), insecure cryptography ($r = 0.54, p < 0.001$), or unencrypted data transmission ($r = 0.47, p < 0.001$) show substantially higher proportions of negative or neutral reviews (28.5% overall). Notably, 553,495 reviews explicitly mention privacy intrusions, data misuse, or operational instability, underscoring the link between vulnerabilities and trust.
- We identify common security patterns across the mHealth ecosystem, including excessive permissions, weak cryptographic practices, and inconsistent enforcement of transport protocols. We translate these into concrete, enforceable recommendations for developer toolchains, app marketplace vetting workflows, and regulatory audits to embed secure-by-design principles prior to deployment.

II. BACKGROUND

Security and privacy in mobile applications are critical, particularly in open ecosystems like Android, where platforms such as Google Play allow unrestricted app publication [5], [21]–[26]. While this openness fosters innovation, it also introduces risks of security flaws, privacy breaches, and regulatory noncompliance [27]. These risks are amplified in healthcare apps that handle PHI and are subject to strict legal and ethical standards. Pham et al. [28] investigated privacy issues in mHealth apps but analyzed a limited sample and overlooked user experience aspects. Other studies have examined runtime behaviors, usability, and permission misuse [27], [29], yet none have simultaneously considered undeclared permissions, cryptographic weaknesses, and user concerns in healthcare. This study addresses that gap.

A. Tools

Over the past decade, open-source and academic communities have developed mature frameworks for static and dynamic mobile app analysis, enabling the detection of insecure permissions, weak cryptography, and privacy-invasive behaviors beyond superficial inspection. We employ three complementary tools in this study. The *Mobile Security Framework* [30] is designed to identify vulnerabilities such as weak hash functions, improper intent handling, cleartext traffic, and excessive permission requests, assigning severity scores for comparative profiling [31]–[36]. *Android Studio* [37] enables permission analysis by categorizing permissions into declared, used, undeclared but used, and

required but unused [38]. This approach is effective for detecting stealthy access to sensitive APIs in healthcare contexts. The *OWASP Mobile App Security Testing Guide* (MASTG) [39], aligned with the *OWASP Mobile Application Security Testing Guide* (MASTG) [40], guides Static Application Security Testing (SAST) to uncover vulnerabilities and assess their severity [41]. We also reference auxiliary tools such as APKLeaks [42] and AndroBugs [43] for lightweight scanning, and note that hybrid fuzzing and penetration testing [44] expand methodological coverage. These capabilities are integrated into a reproducible pipeline tailored for mHealth, targeting code-level threats and privacy practices that circumvent platform enforcement.

B. Mobile Application Privacy and Security

Mobile applications frequently request access to sensitive data and services beyond what is functionally necessary [45]–[51]. While Android’s permission model is designed to promote transparency, users often approve requests without understanding their implications [52]–[55]. As a result, apps frequently request permissions unnecessarily, particularly for sensitive data like location, camera, and contacts. Prior studies [56]–[58] report persistent requests for access to location, camera, SMS, and contact data without clear justification. Liu et al. [59] found that many apps violate the principle of least privilege, requesting sensitive data without justification. Zhang et al. [60] identified *dark patterns*, which are manipulative UI designs that nudge users into granting data access. Such practices reduce transparency and exploit cognitive biases [61]. Tene et al. [62] advocate enforceable, user-centric privacy frameworks, yet enforcement under GDPR and HIPAA remains inconsistent, particularly for consumer-facing health apps that are not subject to medical device regulation [63]. Our findings highlight this gap between regulatory intent and practical enforcement, demonstrating that even highly popular healthcare apps bypass platform protections and fail to meet privacy-by-design standards.

C. Healthcare Applications

mHealth applications manage PHI such as clinical histories, biometric readings, medication records, and behavioral data, making data confidentiality and integrity both technical and ethical imperatives. Mosa et al. [64] classified mHealth into domains ranging from disease management to patient education, revealing highly variable risk profiles. This diversity complicates the uniform application of security standards. Regulatory fragmentation exacerbates the issue. In the United States, only apps that replace or augment clinical devices fall under HIPAA and FDA oversight [59], leaving wellness and lifestyle apps largely unregulated [65]. Reddy et al. [66] documented major breaches linked to insecure healthcare apps, often caused by outdated encryption, absent access controls, or weak transport-layer security. Park et al. [67] and Rafique et al. [68] similarly report persistent use of deprecated algorithms, insecure data storage, and excessive permission requests. An additional risk arises from data brokerage. Shah

et al. [69] found that many mHealth apps embed advertising SDKs and analytics services that exfiltrate user data without meaningful consent, effectively monetizing sensitive health information [70]. While GDPR and HIPAA establish strong principles, enforcement remains inconsistent. Liu et al. [59] call for extending regulation to all apps handling PHI, regardless of classification. Amin et al. [71] explore how to balance privacy preservation with secure data handling in compliance contexts. Our study addresses these blind spots through a fine-grained, tool-assisted analysis of 272 Android healthcare apps, identifying permission abuses, reliance on legacy cryptography, and insecure certificate handling. By triangulating technical findings with over 2.5M user reviews, we reveal a consistent pattern in which usability failures and opaque data practices undermine trust in digital healthcare.

III. METHOD

Our methodology consisted of three phases: (1) *Data Collection and Preprocessing*, (2) *Security and Privacy Analysis*, and (3) *User Experience Analysis*, as shown in Figure 1.

We identified healthcare-related Android applications from Google Play using twenty targeted search queries such as *healthcare*, *medical*, *fitness tracker*, and *telemedicine*. The `google-playstore-scraper` library retrieved the top thirty ranked apps per query, capturing metadata including app IDs, install ranges, developer names, and last update timestamps. Duplicate detection was performed using *SHA-256* hashing of package names and version codes, yielding 292 unique applications. APKs were retrieved from Evozi and APKPure to capture distributable binaries, with preference for the latest release matching the Play Store version. File integrity was verified through cryptographic hash matching, and incomplete or corrupted downloads were discarded. This resulted in 272 valid APKs for static security assessment.

The security and privacy analysis combined three complementary static frameworks to maximise coverage and cross-validation of findings. *MobSF* analyzed all 272 APKs in static mode, disassembling bytecode via `baksmali` and scanning for insecure network endpoints, weak cryptographic primitives, outdated certificate chains, exposed activities or services, and misconfigured manifest entries. Detected issues were assigned severity levels aligned with CWE identifiers, enabling systematic comparison with known vulnerability classes. *RiskInDroid* processed 150 APKs to generate a mapping between requested permissions in the manifest and observed API calls in the compiled code, identifying undeclared-but-used permissions as potential covert channels for sensitive data access. Proprietary and undocumented permissions were flagged by comparing extracted entries against the Android `android.Manifest.permission` namespace, and cross-checked against *MobSF*'s API call traces for corroboration. *OWASP Mobile Audit* examined 95 APKs using static application security testing rules, detecting insecure storage practices such as unencrypted local files or shared preference misuse, hardcoded credentials within source code, and insufficient input validation. Each finding was classified

under the OWASP Mobile Top 10 categories to aid severity prioritization and alignment with industry benchmarks.

For user experience analysis, we collected 2,564,086 reviews from Google Play, including review text, star ratings, app version, timestamp, and user locale. Preprocessing included Unicode normalization, tokenization, stopword removal, and lemmatization to ensure linguistic consistency across English and non-English content. Sentiment analysis was performed using *TextBlob*, applying polarity thresholds of > 0.1 for positive, between -0.1 and 0.1 for neutral, and < -0.1 for negative sentiment. This yielded 1,842,381 positive, 297,976 neutral, and 423,729 negative reviews. The combined 730,705 neutral and negative entries were subjected to n-gram frequency modelling and co-occurrence network analysis to identify patterns of terms associated with security, privacy, and functionality complaints. Manual thematic coding classified feedback into six domains: privacy, security, performance, usability, data collection, and functionality. These themes were cross-referenced with static analysis results to correlate perceived trust issues with objective security weaknesses.

IV. RESULTS

A. MobSF

MobSF assigned a security score to each application based on high- and medium-severity findings across permissions, network security, certificate handling, manifest configuration, and code base analysis. In our dataset, scores ranged from 35 (least secure) to 60 (most secure), with two applications receiving a grade of C. The average score across all 272 applications was 47, indicating that security weaknesses are widespread rather than isolated anomalies.

Dangerous permissions were both common and diverse. Frequently requested high-risk permissions included `POST_NOTIFICATIONS` in 221 applications, `CAMERA` in 176, `WRITE_EXTERNAL_STORAGE` in 204, `READ_EXTERNAL_STORAGE` in 188, and `ACCESS_FINE_LOCATION` in 146. In total, *MobSF* detected 529 proprietary or undocumented permissions, often introduced through third-party SDKs. These included capabilities to access all downloads, read unique device identifiers, and write directly to internal storage. Because such permissions lie outside Android's standard auditing model, their behavior is concealed from both end-users and independent security reviewers.

Network security analysis revealed severe misconfigurations. Twenty-two applications were configured to trust all TLS certificates, 42 allowed cleartext HTTP traffic, and two explicitly disabled certificate pinning. Each of these issues exposes PHI to interception on unsecured or malicious networks. Cryptographic inspection identified 134 applications vulnerable to the *Janus* exploit through flawed signature schemes, 58 using `SHA1-RSA` despite documented collision vulnerabilities, and 9 relying on `MD5`, a hash function that is considered fully broken.

Manifest-level analysis revealed several systemic risks. High-severity findings included 181 apps installable on

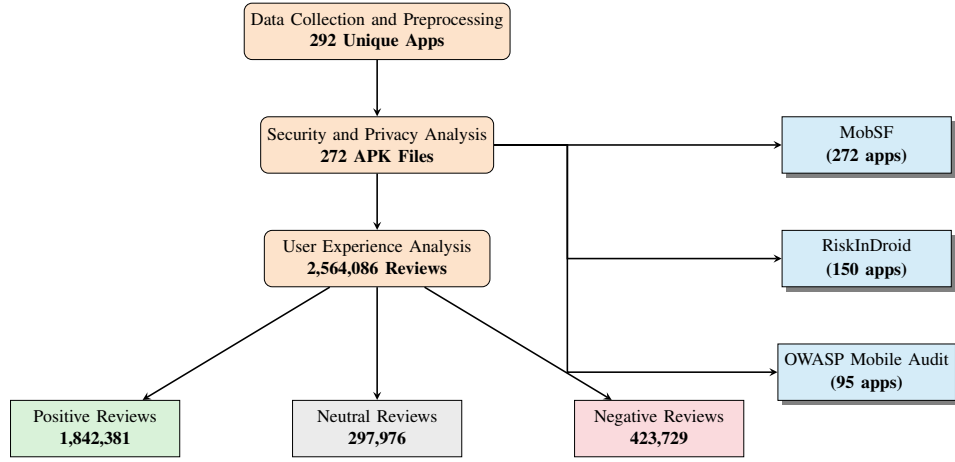


Fig. 1. Study design showing data collection, static security analysis (MobSF, RiskInDroid, OWASP), and sentiment-based review analysis.

outdated Android versions, 118 exposing public asset links, and 6 vulnerable to task hijacking via *StrandHogg* 2.0. Frequent issues involved *android.permission.BROADCAST_STICKY* exposing broadcast receivers, *android.permission.WRITE_SETTINGS* exposing broadcast receivers, and 321 uses of *taskAffinity* that could enable intent interception. Figure 2 shows the distribution of dangerous permissions, emphasizing widespread access to location, camera, and external storage.

B. RiskInDroid

RiskInDroid evaluates applications based on permission usage, where a lower score indicates stronger security posture. The most critical category, *Not Required but Used*, represents permissions actively used without being declared to the user, creating a significant transparency and compliance risk. Figure 3 shows the distribution of these permissions across the analyzed mHealth applications. Across the 150 applications processed, the average RiskInDroid score was 21.57, with a minimum of 5.46 and a maximum of 69.45. The highest score was associated with an APK declaring 17 permissions, 10 of which were used and 7 required but unused, while also using 10 undeclared permissions. High-impact undeclared permissions included *SEND_SMS*, *BROADCAST_STICKY*, *DISABLE_KEYGUARD*, *READ_PHONE_STATE*, and *MANAGE_ACCOUNTS*.

Key statistics include: 110 apps using *AUTHENTICATE_ACCOUNTS*, 148 using *READ_PROFILE*, 71 accessing *ACCESS_FINE_LOCATION*, 75 accessing *ACCESS_COARSE_LOCATION*, 130 writing to settings via *WRITE_SETTINGS*, and 73 sending SMS messages without declaration. In contrast, the most consistently declared permissions included *RECEIVE_BOOT_COMPLETED* (171 apps), *WAKE_LOCK* (296), *ACCESS_WIFI_STATE* (145), and *INTERNET* (302). Table I lists all detected undeclared but used permissions, several of which enable sensitive

capabilities such as account manipulation, location tracking, and network state modification. The high prevalence of such permissions underscores the role of embedded SDKs and inherited code in introducing stealthy data access paths outside Android's normal auditing model.

TABLE I
PERMISSIONS THAT ARE NOT DECLARED BUT USED BY THE APPS -
RISKINDROID

Permission	Count
Send SMS	73
Get Accounts	104
Authenticate Accounts	110
Vibrate	13
Read Profile	148
Receive Boot Completed	22
Broadcast Sticky	77
Access Fine Location	71
Access Coarse Location	75
Change WiFi State	74
Access WiFi State	18
Modify Audio Settings	22
Read Phone State	66
Manage Accounts	117
Use Credentials	44
Access Mock Location	1
Restart Packages	2
Bluetooth Admin	2
Get Tasks	30
Bluetooth	14
Record Audio	4
Wake Lock	3
Disable Keyguard	1
Change WiFi Multicast State	2

C. OWASP Mobile Audit

The OWASP Mobile Audit applies static application security testing (SAST) aligned with the OWASP Mobile Application Security Testing Guide (MASTG) to identify vulnerabilities, insecure configurations, certificate handling issues, and potential malware signatures. Across the 95 mHealth applications analyzed, the mean vulnerability counts per app were:

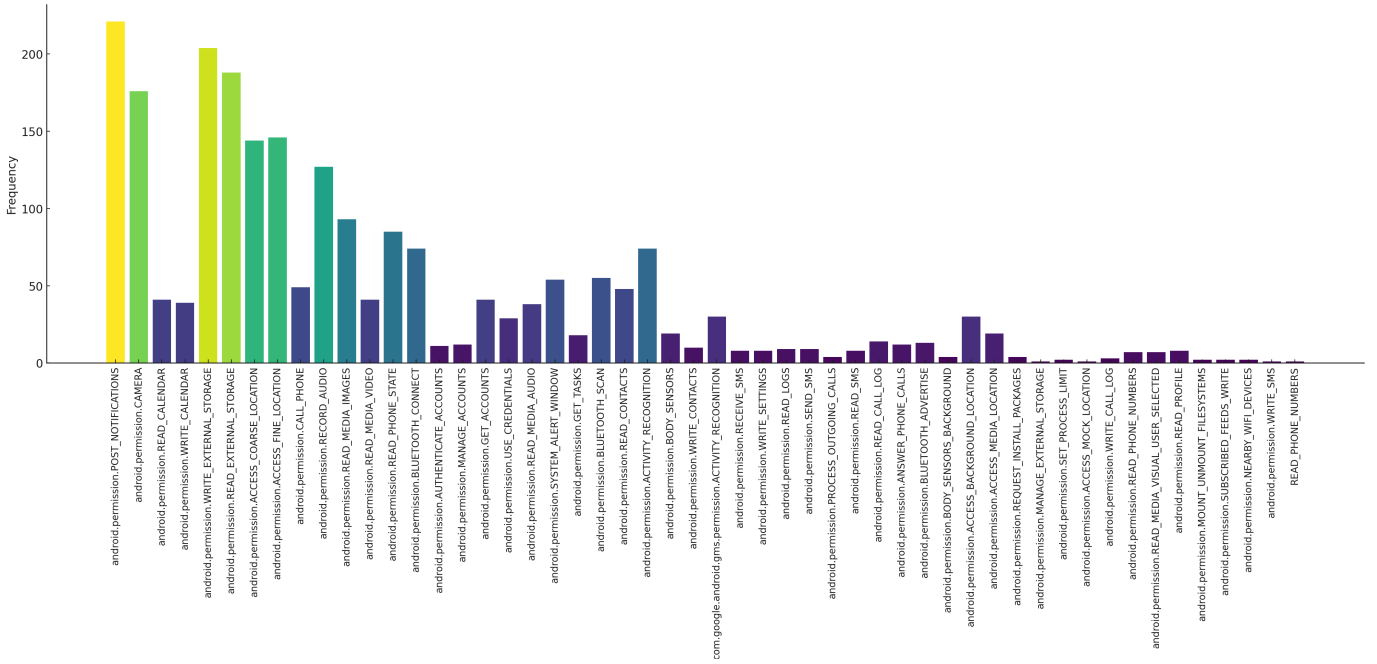


Fig. 2. Distribution of dangerous permissions identified across healthcare applications using RiskInDroid.

44 *critical*, 2,194 *high*, 3,728 *medium*, 1,735 *low*, and 1,469 with no severity assigned. The most vulnerable case recorded 299 critical findings, while the highest number of high-severity issues in a single app reached 11,345. To contextualize these figures, we cross-referenced OWASP’s categorization with the OWASP Mobile Top 10 risk taxonomy, which includes: improper credential usage, inadequate supply chain security, insecure authentication, insufficient input/output validation, insecure communication, inadequate privacy controls, insufficient binary protections, security misconfiguration, insecure data storage, and insufficient cryptography. The average of 44 critical instances per application highlights systemic exposure to these top-tier risks. Frequent critical findings included insecure storage of authentication tokens, absence of certificate pinning, unencrypted PHI transmission, and reliance on outdated cryptographic primitives. The presence of such vulnerabilities at scale suggests that many mHealth applications are deployed without undergoing security verification against recognized industry baselines, leaving both patient data and application integrity susceptible to compromise.

D. Review Analysis

We conducted a large-scale sentiment and term-frequency analysis on user feedback for all 272 applications. Using a Google Play Store scraper, we collected more than 2.5M reviews and processed them with the TextBlob NLP library for sentiment classification. To reduce noise from bots or low-information feedback, we excluded all reviews with fewer than 100 characters. After filtering, each application averaged 8,781 reviews: 6,309 positive, 1,451 negative, and 1,020 neutral. To map user-reported concerns to technical domains, we developed five semantic categories: *confidentiality*, *user*

information, *permissions*, *account access*, and *usable security*. Term extraction and classification revealed that *usable security* issues dominated, appearing in 553,495 reviews. These complaints, consistent with prior observations by Diao et al. [72], referenced interface instability, slow performance, non-responsive features, and repeated authentication failures. *Account access* issues appeared in 154,032 reviews, while *permissions* and *user information* were mentioned in 38,126 and 38,883 reviews respectively. *Confidentiality* concerns, including explicit mentions of privacy violations and PHI exposure, occurred in 15,176 reviews. The category distributions are summarised in Table III. The results show that usability failures in authentication and data access closely align with security weaknesses, indicating shared engineering flaws that undermine both stability and user trust.

Usability A substantial share of user feedback identified persistent failures in authentication workflows, exception handling, and interface stability as barriers to using core functionality. Numerous reviewers reported being locked out of mobile services despite valid credentials, pointing to weaknesses in session lifecycle management, credential verification logic, and consistency between mobile and web authentication flows. These failures were often exacerbated by fragmented password policy enforcement, such as restrictive maximum length limits on mobile clients that conflicted with more permissive web implementations, creating unnecessary friction for security-conscious users. Collectively, such deficiencies were mapped to the *usable security* dimension of our taxonomy, accounting for 553,495 reviews (21.6% of all collected reviews) and representing the single most dominant theme of user dissatisfaction across the dataset.

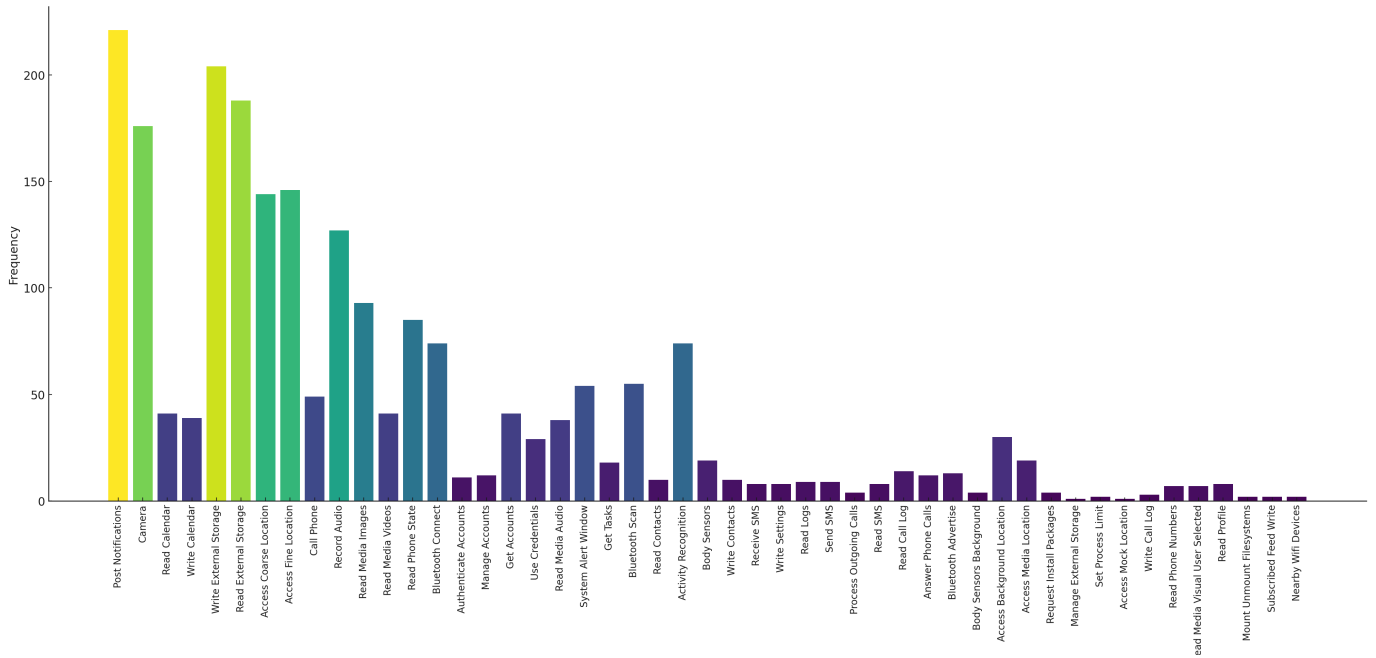


Fig. 3. Distribution of dangerous permissions identified across healthcare applications using RiskInDroid.

TABLE II
SUMMARY OF SECURITY AND PRIVACY FINDINGS BY ANALYSIS TOOL

Tool	Type of Analysis	Key Findings
MobSF (272 apps)	Static code and permission analysis	134 apps use SHA1 vulnerable to Janus 42 apps permit unencrypted traffic 2 apps bypass certificate pinning 181 apps support insecure OS versions 529 unknown permissions detected
RiskInDroid (150 apps)	Permission classification (declared vs undeclared)	73 apps send SMS without disclosure 71 apps access fine location 66 apps read phone state 130 apps write settings silently
OWASP Mobile Audit (95 apps)	Static Application Security Testing (SAST)	Avg 44 critical vulnerabilities per app Top risks: auth, data storage, insecure comms Max: 299 critical, 11,345 high-severity issues

TABLE III
FREQUENCY OF THE REVIEWS BY CATEGORY

Category	Number of Reviews
Confidentiality	15,176
User Info	38,883
Permissions	38,126
Account Access	154,032
Usable Security	553,495

"I have tried using this app after uploading to an iPhone and an Android, numerous times, but unfortunately it will not let me log in, says password is wrong, then when I try to reset password it will not allow me... very disappointed as app does not work."

"App limits the password length shorter than the website so it is impossible to log in to the app with

a secure password."

"Won't let me log in, keeps saying bad request or user not found even though I have done all the steps and have managed to log in through the website."

When authentication succeeded, users often faced degraded in-app performance, including non-responsive UI elements, random freezes, and failed core functions without diagnostic feedback. These suggest poor state management, inadequate input validation, and weak event-handling resilience. Users also described the mobile app as less stable than the web client, indicating issues such as improper API error propagation, thread-management flaws, and unoptimized caching.

"It's a great app for keeping in touch with your doctor. But, there are usability and user-friendliness problems. Certain functions just freeze without any explanation. You are instructed to call support but there are endless recorded messages with no answer."

"It's nice having access to records from two of my healthcare providers. The overall usability and responsiveness of the phone app are not really great, but that is the case for many health information apps."

These weaknesses extend beyond usability. Apps with poor user experience often exhibit critical security flaws such as insecure cryptography ($r = 0.54, p < 0.001$) and unencrypted transmissions ($r = 0.47, p < 0.001$), indicating that weak engineering practices drive both functional instability and exploitable vulnerabilities.

V. DISCUSSION

RQ1: What proportion of mHealth applications exhibit permission overreach, insecure cryptographic implementations, or exploitable vulnerabilities, and how are these weaknesses characterised in static analysis?

Our analysis shows that security weaknesses in mHealth applications are not isolated defects but systemic characteristics of the ecosystem. Static analysis revealed that 26.1% of applications accessed fine-grained location data without user disclosure, 26.8% initiated calls or sent SMS messages without explicit consent, and 24.3% queried phone state without functional justification. RiskInDroid identified 529 proprietary or undocumented permissions, most introduced through third-party SDKs, which bypass Android's public permission framework and create opaque capabilities invisible to both users and external auditors. These permissions often originate from embedded advertising or analytics components and can facilitate device fingerprinting, behavioral profiling, and silent data exfiltration.

On the cryptographic front, 26.0% of applications suffered from *insecure cryptographic implementations*, exposing them to collision-based exploits such as *Janus*, which permits undetected APK modification and repackaging. Forty-two applications transmitted PHI in cleartext over HTTP, enabling trivial interception on public or enterprise Wi-Fi networks using off-the-shelf packet capture tools. Twenty-two accepted all TLS certificates without validation, and two explicitly disabled certificate pinning, giving adversaries an unchallenged path for man-in-the-middle interception of credentials and medical data. Vulnerability scanning also *identified over 100 CVEs*, enabling *side-channel attacks* and *privilege escalation* via *root access*, an attack vector well suited for targeted compromise of telemedicine sessions and insurance workflows. These findings reveal an ecosystem in which insecure defaults, unpatched third-party libraries, and opaque dependencies persist across production codebases, ensuring that exploitable conditions remain available to adversaries at scale.

RQ2: To what extent do technical weaknesses such as insecure permission use, outdated cryptography, and misconfigured network security correlate with user-reported privacy, security, and usability issues in mHealth applications?

Our sentiment analysis of 2.56M Google Play reviews found that 28.5% carried negative or neutral sentiment (423,729

negative, 297,976 neutral), with 553,495 explicitly referencing privacy intrusions, data misuse, or operational instability. These perceptions strongly aligned with the vulnerabilities identified: permission overreach correlated with negative or neutral sentiment ($r = 0.62, p < 0.001$), insecure cryptographic implementations ($r = 0.54, p < 0.001$), and unencrypted transmissions ($r = 0.47, p < 0.001$). Users frequently reported unjustified access to location, camera, or contacts, mirroring our detection of undeclared or high-risk permissions in static analysis.

Performance complaints such as persistent crashes, input lag, and long load times often appeared alongside insecure cryptography or permissive network configurations. This pattern suggests that weak engineering practice manifests in both degraded functional reliability and a weakened security posture. Notably, a subset of users explicitly equated instability with insecure handling of personal data, demonstrating that perceived operational quality forms part of an implicit trust model. Once this trust is undermined, reputational damage can occur even in the absence of a confirmed breach, increasing the likelihood of user attrition and regulatory attention.

RQ3: What misconfiguration and permission misuse patterns can be extracted from this evidence, and how can they inform enforceable secure-by-design and regulatory practices?

Our findings suggest that, first, developers should integrate security checks into their CI/CD pipelines, and second, app marketplaces should enforce strict review of permissions and network security. Third, regulatory bodies should mandate secure-by-design principles, and developers should adopt secure defaults such as certificate pinning and encrypted transmissions. Finally, on insecure defaults, setting other the default developer intent.

Addressing these weaknesses requires mandatory secure-by-design enforcement at the tooling and governance levels. Secure defaults should be embedded into SDKs, IDE templates, and CI/CD pipelines so that least-privilege permissions, certificate pinning, and strong cryptographic suites (RSA 2048+ with SHA-256 or ECDSA P-256) are automatically configured. App marketplaces should require machine-verifiable pre-publication audits covering permission declarations, cryptographic configurations, and network protections, with automatic rejection of binaries that fail baseline checks. Proprietary permissions must be disclosed, documented, and justified to the same standard as Android's core permission set. Undisclosed capabilities should be treated as explicit policy violations subject to financial penalties and removal from distribution channels. Without such measures, the structural defects we identify will persist and continue to undermine both user trust and the confidentiality of PHI.

VI. IMPLICATIONS

Our findings reveal systemic weaknesses in the mHealth ecosystem, which operates at the intersection of sensitive data

handling, platform controls, and user trust. Despite regulatory attention, enforcement and secure engineering remain inconsistent. We identify four priority areas encompassing platform enforcement, secure-by-design development, user transparency, and regulatory modernization, all supported by automated socio-technical vetting pipelines.

A. Platform Policy Enforcement

In this study, we examined Android applications, whose permission framework is designed for least-privilege use, yet enforcement is uneven. Many apps in our dataset bypass consent by exploiting undeclared or proprietary permissions, often accessing sensitive data such as location, SMS, and device identifiers. Google Play’s review process prioritizes malware detection but rarely flags static privacy violations, including insecure certificate configurations and privileged API use [73], [74]. To close this gap, marketplaces should embed automated tools such as RiskInDroid [37], MobSF [30], and OWASP Mobile Audit [39] directly into submission workflows. Extending these checks to silent permission use, legacy cryptography, and telephony misuse, combined with manifest-to-behavior audits and update-time differential analysis, would help detect and prevent privilege escalation.

B. By-Design Engineering

Weak enforcement is compounded by insecure development practices. Nearly half of evaluated apps still rely on deprecated cryptography (SHA-1, MD5), and known exploits such as Janus and StrandHogg 2.0 remain exploitable. This reflects inconsistent integration of SAST/DAST tools into CI/CD pipelines. Developers should adopt the OWASP MASVS [40], embed security linters into IDEs, and align authentication with NIST SP 800-63B [75]. To address risks from third-party SDKs, SBOM generation and automated dependency scanning should become prerequisites for app store submission [76].

Users notice when app behavior conflicts with stated purpose. Permission–function mismatches, especially for location, SMS, and contacts, frequently erode trust [77]. Progressive, context-aware permission flows [78] can reduce suspicion, while platform rules should prohibit dark patterns that coerce consent, in line with EU Digital Services Act requirements [79]. At scale, NLP-based monitoring of app reviews could surface privacy concerns early, allowing developers to intervene before reputational damage occurs.

C. Regulation of Gray-Zone Health Apps

Trust also depends on regulatory coverage. Frameworks such as HIPAA and GDPR focus on clinical providers, leaving many gray-zone apps (e.g., fitness trackers, symptom checkers) outside formal oversight despite their collection of PHI-equivalent data [80]. Regulators should broaden the definition of health data handlers to cover any entity processing biometric or medical information [63]. Privacy nutrition labels in app stores and independent certification schemes (e.g., SOC 2–style for mHealth) would provide clearer accountability and verifiable standards [81].

D. Automated Vetting and Socio-Technical Oversight

Finally, sustaining improvements requires moving beyond manual audits. Continuous vetting pipelines that combine static and dynamic analysis, taint tracking, permission mapping, and traffic anomaly detection can expose covert channels and privilege escalation paths [82]. Sandboxed monitoring of CPU, sensor, and network activity adds runtime assurance. For decision-makers, explainable dashboards built on tools like MobSF and RiskInDroid can translate technical findings into actionable insights [76], supporting coordinated socio-technical oversight.

VII. LIMITATIONS AND FUTURE WORK

We conducted an assessment of 272 mHealth applications, but our analysis faced constraints from tools like *RiskInDroid* and *OWASP Mobile Audit*, which could not process some large APKs due to file size limits. We mitigated this by combining multiple static analysis tools, yet static methods cannot fully capture runtime behaviors such as time-triggered data exfiltration, dynamic code loading, or conditional permission escalation. In future work, we will integrate dynamic analysis capable of monitoring real-time network activity and execution flows, expand coverage to iOS mHealth apps for cross-platform comparison, and perform longitudinal tracking to assess whether identified vulnerabilities are remediated or persist across release cycles.

VIII. CONCLUSION

mHealth applications are integral to clinical and wellness workflows, yet our analysis of 272 Android mHealth apps shows that fundamental security and privacy controls are routinely bypassed. We found 134 apps (49.3%) still signed with deprecated RSA SHA-1 certificates vulnerable to Janus, 42 (15.4%) transmitting PHI in cleartext, and 6 (2.2%) exploitable via *StrandHogg 2.0*. RiskInDroid detected 529 undeclared permissions, including 73 apps (26.8%) silently sending SMS, 144 (52.9%) accessing fine location without disclosure, and 66 (24.3%) unnecessarily reading phone state. Additionally, 22 apps (8.1%) accepted all TLS certificates and 2 (0.7%) bypassed certificate pinning entirely, creating trivial man-in-the-middle risks. These weaknesses are statistically linked to user distrust: permission overreach ($r = 0.62, p < 0.001$), insecure cryptography ($r = 0.54, p < 0.001$), and unencrypted transmissions ($r = 0.47, p < 0.001$) correlate with 553,495 user reviews citing privacy breaches, data misuse, or operational instability. Overall, the findings indicate that insecure engineering is a systemic issue within the mHealth ecosystem. Our reproducible methodology, combining static analysis, permission forensics, and sentiment mining, offers a scalable model for app store vetting, supporting integration into review pipelines, mandatory permission disclosure, and stronger regulation for PHI-processing apps.

REFERENCES

- [1] A. S. M. Mosa, I. Yoo, and L. Sheets, “A systematic review of healthcare applications for smartphones,” *BMC medical informatics and decision making*, vol. 12, pp. 1–31, 2012.

- [2] Y. Y. Shieh, F. Y. Tsai, A. Anavim, M. D. Wang, and C.-M. C. Lin, "Mobile healthcare: Opportunities and challenges," in *International Conference on the Management of Mobile Business (ICMB 2007)*, 2007, pp. 50–50.
- [3] M. Duckert and L. Barkhuus, "Protecting personal health data through privacy awareness: A study of perceived data privacy among people with chronic or long-term illness," *Proceedings of the ACM on Human-Computer Interaction*, vol. 6, no. GROUP, pp. 1–22, 2022.
- [4] F. Tazi and S. Das, "Evaluating telehealth for women in mexico: Privacy, usability, and integration challenges in remote healthcare," *Usability, and Integration Challenges in Remote Healthcare (July 15, 2024)*, 2024.
- [5] S. Saka and S. Das, "Evaluating privacy measures in healthcare apps predominantly used by older adults," in *2024 Conference on Building a Secure & Empowered Cyberspace (BuildSEC)*. IEEE, 2024, pp. 79–86.
- [6] S. Das, K. Madathil, J. Dykstra, P. Rajivan, S. Setty, J. T. McElligott, J. Hughart, and D. Votipka, "Privacy and security of telehealth services," in *Proceedings of the Human Factors and Ergonomics Society Annual Meeting*, vol. 66, no. 1. SAGE Publications Sage CA: Los Angeles, CA, 2022, pp. 1524–1528.
- [7] F. Tazi, A. Nandakumar, J. Dykstra, P. Rajivan, and S. Das, "Sok: Analyzing privacy and security of healthcare data from the user perspective," *ACM Transactions on Computing for Healthcare*, vol. 5, no. 2, pp. 1–31, 2024.
- [8] F. Tazi, J. Dykstra, P. Rajivan, and S. Das, "Sok: Evaluating privacy and security vulnerabilities of patients' data in healthcare," in *International workshop on socio-technical aspects in security*. Springer, 2022, pp. 153–181.
- [9] H. Kupwade Patil and R. Seshadri, "Big data security and privacy issues in healthcare," in *2014 IEEE International Congress on Big Data*, 2014, pp. 762–765.
- [10] G. Osawaru, "Electronic health record data breaches in us healthcare industry: A quantitative study using the protection motivation theory (pmt) to mitigate data breaches," Ph.D. dissertation, University of the Cumberlands, 2024.
- [11] A. Surani, A. Bawaked, M. Wheeler, B. Kelsey, N. Roberts, D. Vincent, and S. Das, "Security and privacy of digital mental health: An analysis of web services and mobile applications," in *IFIP Annual Conference on Data and Applications Security and Privacy*. Springer, 2023, pp. 319–338.
- [12] A. Surani and S. Das, "Understanding privacy and security postures of healthcare chatbots," in *Proceedings of the 2022 CHI Conference on Human Factors in Computing Systems. Presented at: CHI*, vol. 22, 2022, pp. 1–7.
- [13] T. Alshugran and J. Dichter, "Extracting and modeling the privacy requirements from hipaa for healthcare applications," in *IEEE Long Island Systems, Applications and Technology (LISAT) Conference 2014*, 2014, pp. 1–5.
- [14] M. Tzanou, *Health Data Privacy Under the GDPR*. TAYLOR FRANCIS Limited, 2023.
- [15] M. Grover and S. Das, "Sok: A systematic review of privacy and security in healthcare robotics," *Available at SSRN 5356100*, 2025.
- [16] A. Adhikari, S. Das, and R. Dewri, "Natural language processing of privacy policies: A survey," *arXiv preprint arXiv:2501.10319*, 2025.
- [17] F. Tazi, J. Dykstra, P. Rajivan, and S. Das, "we have no security concerns": Understanding the privacy-security nexus in telehealth for audiologists and speech-language pathologists," in *Proceedings of the 2024 CHI Conference on Human Factors in Computing Systems*, 2024, pp. 1–20.
- [18] A. Adhikari, S. Das, and R. Dewri, "Evolution of composition, readability, and structure of privacy policies over two decades," *Proceedings on Privacy Enhancing Technologies*, 2023.
- [19] F. Tazi, J. Dykstra, P. Rajivan, K. Chalil Madathil, J. Hughart, J. McElligott, D. Votipka, and S. Das, "Improving privacy and security of telehealth," *Communications of the ACM*, vol. 67, no. 9, pp. 27–30, 2024.
- [20] C. Monroe, F. Tazi, and S. Das, "Location data and covid-19 contact tracing: how data privacy regulations and cell service providers work in tandem," *arXiv preprint arXiv:2103.14155*, 2021.
- [21] S. Das, "Design of secure, privacy-focused, and accessible e-payment applications for older adults," in *2024 Conference on Building a Secure & Empowered Cyberspace (BuildSEC)*. IEEE, 2024, pp. 74–78.
- [22] U. Kishnani, N. Noah, S. Das, and R. Dewri, "Assessing security, privacy, user interaction, and accessibility features in popular e-payment applications," in *Proceedings of the 2023 European Symposium on Usable Security*, 2023, pp. 143–157.
- [23] U. Kishnani, I. Cardenas, J. Castillo, R. Conry, L. Rodwin, R. Ruiz, M. Walther, and S. Das, "Towards perceived security, perceived privacy, and the universal design of e-payment applications," *arXiv preprint arXiv:2407.05446*, 2024.
- [24] U. Kishnani and S. Das, "Dual-technique privacy & security analysis for e-commerce websites through automated and manual implementation," *arXiv preprint arXiv:2410.14960*, 2024.
- [25] U. Kishnani, N. Noah, S. Das, and R. Dewri, "Privacy and security evaluation of mobile payment applications through user-generated reviews," in *Proceedings of the 21st Workshop on Privacy in the Electronic Society*, 2022, pp. 159–173.
- [26] S. Neupane, F. Tazi, U. Paudel, F. V. Baez, M. Adamjee, L. De Carli, S. Das, and I. Ray, "On the data privacy, security, and risk postures of iot mobile companion apps," in *IFIP Annual Conference on Data and Applications Security and Privacy*. Springer, 2022, pp. 162–182.
- [27] M. Backes, S. Bugiel, and E. Derr, "Quantifying permission-creep in the google play store," *arXiv preprint arXiv:1606.01708*, 2016. [Online]. Available: <https://arxiv.org/html/1606.01708v1>
- [28] H. Pham, A. Carollo, P. Saxena, and N. Zeldovich, "Oat: Attesting operation integrity of embedded devices," in *28th USENIX Security Symposium (USENIX Security 19)*, 2019, pp. 1431–1448. [Online]. Available: <https://www.usenix.org/system/files/sec19-pham.pdf>
- [29] K. Marky, A. Voit, A. Stöver, K. Kunze, S. Schröder, and M. Mühlhäuser, "i don't know how to protect myself": Understanding privacy perceptions resulting from the presence of bystanders in smart environments," in *Proceedings of the 11th Nordic Conference on Human-Computer Interaction: Shaping Experiences, Shaping Society*, 2020, pp. 1–11.
- [30] A. Abraham, D. Schlecht, G. Ma, M. Dobrushin, and V. Nadal, "Mobile security framework (mobsf)," in *GitHub Repository*. GitHub, 2016.
- [31] M. Tileria, J. Blasco, and G. Suarez-Tangil, "{WearFlow}: Expanding information flow analysis to companion apps in wear {OS}," in *23rd International Symposium on Research in Attacks, Intrusions and Defenses (RAID 2020)*, 2020, pp. 63–75.
- [32] B. Kalhor and S. Das, "Evaluating the security and privacy risk postures of virtual assistants," *arXiv preprint arXiv:2312.14633*, 2023.
- [33] K. Jensen, F. Tazi, and S. Das, "Multi-factor authentication application assessment: Risk assessment of expert-recommended mfa mobile applications," *Proceeding of the Who Are You*, 2021.
- [34] N. Noah, S. Thakur, J. Beck, and S. Das, "Aging safely online: Unpacking privacy & security of online dating for older adults," in *Proceedings of the Human Factors and Ergonomics Society Annual Meeting*, vol. 68, no. 1. SAGE Publications Sage CA: Los Angeles, CA, 2024, pp. 230–235.
- [35] —, "Evaluating privacy & security of online dating applications with a focus on older adults," in *2024 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW)*. IEEE, 2024, pp. 666–677.
- [36] N. Noah, U. Kishnani, S. Das, and R. Dewri, "Privacy and security evaluation of mobile payment applications through user-generated reviews," in *Workshop on Privacy in the Electronic Society (WPES'22)*, 2022.
- [37] A. Merlo and G. C. Georgiu, "Riskindroid: Machine learning-based risk analysis on android," in *ICT Systems Security and Privacy Protection: 32nd IFIP TC 11 International Conference, SEC 2017, Rome, Italy, May 29-31, 2017, Proceedings 32*. Springer, 2017, pp. 538–552.
- [38] L. Khorkheli, D. Bourne, V. Chakravarty, S. Abraham, G. B. Satrya, and A. B. Mnaouer, "Improving otp authentication with pqc algorithms," in *2024 Global Information Infrastructure and Networking Symposium (GIIS)*. IEEE, 2024, pp. 1–6.
- [39] O. Foundation, "Owasp mobile audit project," in *OWASP Website*. OWASP, 2023.
- [40] —, "Owasp mobile application security testing guide (mastg) v1.7.0," <https://github.com/OWASP/owasp-mastg/releases/tag/v1.7.0>, 2023, accessed: 2025-04-24.
- [41] U. Kishnani and S. Das, "Securing the web: Analysis of http security headers in popular global websites," in *International Conference on Information Systems Security*. Springer, 2024, pp. 87–106.
- [42] C. T. Miraroad, "Apkleaks: A mobile security tool," in *Medium*. Medium, 2023.
- [43] AndroBugs, "Androbugs framework," in *GitHub Repository*. GitHub, 2023.
- [44] P. Chandra, "Web testing and security audit of web application," in *ResearchGate*. Research Gate, 2023.

- [45] I. Leontiadis, C. Efstratiou, M. Picone, and C. Mascolo, "Don't kill my ads! balancing privacy in an ad-supported mobile application market," in *Proceedings of the Twelfth Workshop on Mobile Computing Systems & Applications*, 2012, pp. 1–6.
- [46] B. Momenzadeh, S. Gopavaram, S. Das, and L. J. Camp, "Bayesian evaluation of user app choices in the presence of risk communication on android devices," in *International Symposium on Human Aspects of Information Security and Assurance*. Springer, 2020, pp. 211–223.
- [47] S. Das, J. Abbott, S. Gopavaram, J. Blythe, and L. J. Camp, "User-centered risk communication for safer browsing," in *International conference on financial cryptography and data security*. Springer, 2020, pp. 18–35.
- [48] F. Tazi, S. Saka, G. Opp, S. Neupane, S. Das, L. De Carli, and I. Ray, "Accessibility evaluation of iot android mobile companion apps," in *Extended Abstracts of the 2023 CHI Conference on Human Factors in Computing Systems*, 2023, pp. 1–7.
- [49] M. Sun, J. C. Lui, and Y. Zhou, "Blender: Self-randomizing address space layout for android apps," in *Research in Attacks, Intrusions, and Defenses: 19th International Symposium, RAID 2016, Paris, France, September 19-21, 2016, Proceedings 19*. Springer, 2016, pp. 457–480.
- [50] B. Momenzadeh, S. Gopavaram, S. Das, and L. J. Camp, "Bayesian evaluation of privacy-preserving risk communication for user android app preferences," *Information & Computer Security*, vol. 29, no. 4, pp. 680–693, 2021.
- [51] V. H. Podapati, D. Nigam, and S. Das, "Sok: A systematic review of context-and behavior-aware adaptive authentication in mobile environments," *arXiv preprint arXiv:2507.21101*, 2025.
- [52] E. Fife and J. Orjuela, "The privacy calculus: Mobile apps and user perceptions of privacy and security," in *International Journal of Engineering Business Management*, vol. 4. SAGE Publications, 2012.
- [53] J. Streiff, S. Das, and J. Cannon, "Overpowered and underprotected toys empowering parents with tools to protect their children," in *2019 IEEE 5th International Conference on Collaboration and Internet Computing (CIC)*. IEEE, 2019, pp. 322–329.
- [54] B. Debnath, A. Das, S. Das, and A. Das, "Studies on security threats in waste mobile phone recycling supply chain in india," in *2020 IEEE Calcutta Conference (CALCON)*. IEEE, 2020, pp. 431–434.
- [55] J. Dev, S. Das, Y. Rashidi, and L. J. Camp, "Personalized whatsapp privacy: Demographic and cultural influences on indian and saudi users," Available at SSRN 3391021, 2019.
- [56] X. Wei, L. Gomez, I. Neamtiu, and M. Faloutsos, "Permission evolution in the android ecosystem," in *Proceedings of the 28th Annual Computer Security Applications Conference*, ser. ACSAC '12. New York, NY, USA: Association for Computing Machinery, 2012, p. 31–40. [Online]. Available: <https://doi.org/10.1145/2420950.2420956>
- [57] T. Tvidas, H. Hang, N. Viennot, X. Zhang, and J. Nieh, "All your droid are belong to us: A survey of current android attacks," in *Proceedings of the Web 2.0 Security and Privacy Workshop (W2SP)*, 2011.
- [58] N. Sivan, R. Bitton, and A. Shabtai, "Analysis of location data leakage in the internet traffic of android-based mobile devices," in *22nd International Symposium on Research in Attacks, Intrusions and Defenses (RAID 2019)*, 2019, pp. 243–260.
- [59] C. Liu, Q. Zhu, K. A. Holroyd, and E. K. Seng, "Status and trends of mobile-health applications for ios devices: A developer's perspective," *Journal of Systems and Software*, vol. 84, no. 11, pp. 2022–2033, 2011, mobile Applications: Status and Trends. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S0164121211001610>
- [60] D. Roy, N. Kumar, and S. Das, "Examining the double-edged sword of digital contact tracing apps in india," in *Proceedings of the 2023 CHI Conference on Human Factors in Computing Systems*, 2023. [Online]. Available: <https://dl.acm.org/doi/abs/10.1145/3637336>
- [61] A. Webson and E. Pavlick, "Do prompt-based models really understand the meaning of their prompts?" in *Proceedings of the 2022 Conference of the North American Chapter of the Association for Computational Linguistics: Human Language Technologies*, 2022, pp. 2300–2344.
- [62] H. Zhu, H. Xiong, Y. Ge, and E. Chen, "Mobile app recommendations with security and privacy awareness," in *Proceedings of the 20th ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*, ser. KDD '14. New York, NY, USA: Association for Computing Machinery, 2014, p. 951–960. [Online]. Available: <https://doi.org/10.1145/2623330.2623705>
- [63] A. P. Gurses *et al.*, "Challenges and opportunities for improving patient safety through human factors and systems engineering," *Journal of Patient Safety and Risk Management*, vol. 27, pp. 15–22, 2022.
- [64] A. Agrawal, S. Kumar, and R. Tiwari, "Decision support system for detecting diabetic retinopathy using smartphones," in *BMC Medical Informatics and Decision Making*. Springer, 2012.
- [65] A. Moen and P. F. Brennan, "Health@ home: the work of health information management in the household (himh): implications for consumer health informatics (chi) innovations," *Journal of the American Medical Informatics Association*, vol. 12, no. 6, pp. 648–656, 2005.
- [66] M. Ozer, "A review on data breaches in healthcare security systems," *ResearchGate*, 2023.
- [67] S. Park and H.-Y. Youm, "Security and privacy threats and requirements for the centralized contact tracing system in korea," *Big Data and Cognitive Computing*, vol. 6, no. 4, p. 143, 2022.
- [68] H. F. Ahmad, W. Rafique, R. U. Rasool, A. Alhumam, Z. Anwar, and J. Qadir, "Leveraging 6g, extended reality, and iot big data analytics for healthcare: A review," *Computer Science Review*, vol. 48, p. 100558, 2023. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S1574013723000254>
- [69] M. Shah and F. C. B. Lim, "An analysis of australian online third-party arrangements: past, current and future," *Perspectives: Policy and Practice in Higher Education*, vol. 28, no. 4, pp. 191–201, 2024. [Online]. Available: <https://doi.org/10.1080/13603108.2023.2268058>
- [70] E.-P. Fernández Manzano and M. I. González Vasco, "Analytic surveillance: Big data business models in the time of privacy awareness," *El Profesional de la Información*, 2018.
- [71] M. A. Amin, H. Tummala, R. Shah, and I. Ray, "Balancing patient privacy and health data security: The role of compliance in protected health information (phi) sharing," *arXiv preprint arXiv:2407.02766*, 2024.
- [72] W. Diao, Y. Zhang, L. Zhang, Z. Li, F. Xu, X. Pan, X. Liu, J. Weng, K. Zhang, and X. Wang, "Kindness is a risky business: On the usage of the accessibility {APIs} in android," in *22nd International Symposium on Research in Attacks, Intrusions and Defenses (RAID 2019)*, 2019, pp. 261–275.
- [73] Z. Muhammad, F. Amjad, Z. Iqbal, A. R. Javed, and T. R. Gadekallu, "Circumventing google play vetting policies: A stealthy cyberattack that uses incremental updates to breach privacy," *Journal of Ambient Intelligence and Humanized Computing*, vol. 14, no. 5, pp. 4785–4794, 2023.
- [74] B. Andow, S. Y. Mahmud, W. Wang, J. Whitaker, W. Enck, B. Reaves, K. Singh, and T. Xie, "{PolicyLint}: investigating internal privacy policy contradictions on google play," in *28th USENIX security symposium (USENIX security 19)*, 2019, pp. 585–602.
- [75] I. A. Chatzipavlou, S. A. Christoforidou, and M. Vlachopoulou, "A recommended guideline for the development of mhealth apps," *Mhealth*, vol. 2, p. 21, 2016.
- [76] J. T. Stoddard, M. A. Cutshaw, T. Williams, A. Friedman, and J. Murphy, "Software bill of materials (sbom) sharing lifecycle report," Idaho National Laboratory (INL), Idaho Falls, ID (United States), Tech. Rep., 2023.
- [77] D. Lupton, "M-health and health promotion: The digital cyborg and surveillance society," *Social Theory & Health*, vol. 10, pp. 229–244, 2012.
- [78] G. Bai, L. Gu, T. Feng, Y. Guo, and X. Chen, "Context-aware usage control for android," in *Security and Privacy in Communication Networks: 6th International ICST Conference, SecureComm 2010, Singapore, September 7-9, 2010. Proceedings 6*. Springer, 2010, pp. 326–343.
- [79] A. P. Heldt, "Eu digital services act: The white hope of intermediary regulation," in *Digital platform regulation: Global perspectives on internet governance*. Springer International Publishing Cham, 2022, pp. 69–84.
- [80] R. S. Istepanian, "Mobile health (m-health) in retrospect: the known unknowns," *International journal of environmental research and public health*, vol. 19, no. 7, p. 3747, 2022.
- [81] K.-U. Loser and M. Degeling, "Security and privacy as hygiene factors of developer behavior in small and agile teams," in *ICT and Society: 11th IFIP TC 9 International Conference on Human Choice and Computers, HCC11 2014, Turku, Finland, July 30–August 1, 2014. Proceedings 11*. Springer, 2014, pp. 255–265.
- [82] L. Nurgalieva, D. O'Callaghan, and G. Doherty, "Security and privacy of mhealth applications: a scoping review," *IEEE Access*, vol. 8, pp. 104 247–104 268, 2020.